

Private case evidence and timeline — integrated review build

User journey implemented

Sign in → create a workspace → create a case with named sites → import original files → inspect extracted passages → review dated entries → search this or earlier authorised cases → export a reviewed PDF and its provenance manifest.

This integrates the work from draft PRs #26, #27 and #28 with actual parsing, persistence and export. It is not a production release. No production database has been migrated or seeded, and no confidential user files were used in tests.

Supported sources

- Text-bearing PDF: page-numbered passages; at most 100 pages.
- DOCX: extracted body offsets, not invented page numbers.
- EML: plain-text email body, original Date header retained separately from event dates, supported attachments linked to the email. The original MIME file is retained. Remote images and HTML are not rendered. An unsupported attachment rejects the email import; nested attachment depth is limited to one.
- UTF-8 TXT and CSV: source text; CSV column meanings, units and calculations are not inferred.
- PNG/JPEG and scanned PDFs: originals retained with `NEEDS_OCR`. Automatic OCR and a manual transcription editor are not implemented; these files do not yet create timeline entries.
- Optional user-supplied source URL and publication date are references, not fetched/verified content. Attachments do not inherit their parent's publication date/source URL.

Files are limited to 5 MiB each, five per UI batch, 100 documents / 50 MiB / 1,500 passages per case. Each document has at most 150 passages. Duplicates reuse identical bytes in the same case; conflicting supplied metadata returns an explicit conflict. An amendment references an earlier document without deleting it. Repeated attachment occurrences are retained in the email metadata even when the attached bytes already exist.

Review, retrieval and case packs

Each extracted passage produces a draft suggestion, not an AI-verified event. Only unambiguous ISO dates are suggested; reviewers may retain unknown/year/month/day precision. A reviewed quotation must occur in its source passage. Reviews append revisions, use optimistic concurrency, and retain the previous representation. Acceptance is faithful source representation, not proof of an allegation.

Search is literal substring matching in source passages, not vector/semantic search. Other-case results are restricted to current memberships in the same workspace. Opening a result does not copy it into a new case or broaden permissions. No private text enters the public search/ingestion pipeline.

The reveal slider displays the dated timeline; it is not a satellite/historical-map comparison. PDF exports contain all accepted entries, including labelled superseded records and unknown dates. Current UI filters do not change that export. The manifest records parser/renderer versions, exact revisions, source hashes/locators, omitted draft/rejected revisions and the issued PDF hash. Exports are retained byte-for-byte and re-authorised at download. Limits: 400 accepted entries, 150 pages, 5 MiB per PDF

and 20 exports per case. There is no redaction editor or implied court-admissibility guarantee. Unsupported PDF core-font characters are displayed explicitly as Unicode code points; the JSON manifest retains full text.

Privacy and release requirements

Runtime requirement: Node 22.13 or newer, matching the PDF parser's supported engines. The forked parser is launched through a worker path assembled at runtime so the production bundler (Turbopack) does not attempt to resolve the worker as a statically imported module; subprocess isolation, the restricted environment, the memory cap and the time limit are unchanged. For the deployed standalone package to physically contain the forked parser and its lazy dependency closure (`pdfjs-dist` , `mammoth` , `mailparser`), `next.config.js` must declare `serverExternalPackages` plus an `outputFileTracingIncludes` entry for `/api/workspaces/**` (computed by `lib/workspaces/trace-parser.cjs`).

Platform restriction on this configuration. On this hosting platform `next.config.js` is managed: direct edits are rejected and each checkpoint restores the platform-managed file, so the `serverExternalPackages` / `outputFileTracingIncludes` block cannot be persisted through a checkpoint or a deployment from source control. The runtime parser fix in `lib/workspaces/parser.ts` **does** persist and is sufficient for the production build to compile. The dependency-tracing block was verified to produce a correct, runnable package by reproducing the platform's exact packaging build in an isolated directory (see below); persisting it in the deployed environment is a release task owned by the platform/deployment owner, and only becomes load-bearing once the private feature is enabled (all private-workspace flags remain disabled).

MFA is a release blocker. Existing authentication is email/password only. Neither a workspace membership nor `PRIVATE_EVIDENCE_RUNTIME_APPROVED` constitutes MFA. Before confidential pilot use, configure an approved organisational identity provider with enforced MFA (prefer phishing-resistant passkeys/security keys), controlled account recovery and tested offboarding. Do not invent identity-provider assurance from an email domain or an unchecked client claim. The identity tenant, application registration and deployment route are not available in this checkout; MFA/SSO has not been integrated or activated.

Workspace AND case membership are checked server-side. Owners/reviewers control review; owners separately grant their own exports. Subscription roles are not private-case access. Revoked access blocks originals, search and retained export downloads. Requests are same-origin checked, bounded and no-store. The UI does not persist private case data in browser storage.

Original file bytes and PDF bytes use AES-256-GCM with context-bound authentication. **Extracted passages, metadata, review history and manifest columns are not application-encrypted:** approve database encryption at rest, access control, backups and retention before production. Hold the 32-byte encryption key in the secret manager with a tested recovery plan; key loss makes originals unreadable. Key rotation, retention/deletion tooling and invitation/member-management UI are not delivered.

Imports fail closed unless all three flags in `.env.example` are enabled and the encryption key is configured. The host must install `clamscan` and maintain its signatures. The parser child receives no application secrets and has a 20-second time / 128 MiB V8 heap limit. **A child process is not a complete sandbox:** native memory, host filesystem and network require externally enforced restrictions. The in-process two-job / one-job-per-actor limit is not a distributed quota. Approval must include global request limits, a constrained parser runtime and malicious compressed-input testing.

The global third-party Abacus browser script was removed to prevent private DOM access. The platform-managed instrumentation has a private-workspace suppression; confirm that the deployment preserves it rather than regenerating an exfiltrating hook. The workspace CSP blocks external connections. The legacy external PDF flow stays off by default and is separate from local private case PDFs.

Validation and precise limits

The build command actually validated for this repair is the platform's own production build (Turbopack, standalone output) — a Webpack-only build or a working development preview is explicitly treated as insufficient. Run from `nextjs_space` :

```
node --import ./node_modules/tsx/dist/loader.mjs --test tests/case-files.test.ts
tests/private-workspaces.test.ts tests/workspace-client.test.mjs tests/pdf-job-access.test.mjs
node --import ./node_modules/tsx/dist/loader.mjs --test tests/evidence-*.test.ts
tests/place-history.test.ts tests/investigation-coverage.test.ts
node node_modules/typescript/bin/tsc --noEmit --incremental false
node node_modules/prisma/build/index.js validate
NODE_OPTIONS="--max-old-space-size=10240" __NEXT_TEST_MODE= NEXT_DIST_DIR=.build
NEXT_OUTPUT_MODE=standalone yarn run build
```

The production build above is the exact command the platform runs at deploy time. Because the project's `node_modules` is a symlink into the shared managed store, the standalone build must run where `node_modules` is a real directory inside the tracing root; this is reproduced by copying the managed app directory into an isolated path and rsyncing the working tree over it (mirroring the platform's packaging step), exactly as the platform does. In that faithful packaging build the production build compiles successfully with zero `server relative imports / Can't resolve .../parser-process.mjs` errors; reverting only the worker-launch line to a static literal path reproduces those exact errors, confirming the fix addresses this specific failure. The packaged output was then exercised directly: the forked `parser-process.mjs` was run from `.build/standalone/app` against synthetic PDF, DOCX, EML, TXT and CSV inputs and all five parsed (`status=PARSED`) using only the dependencies traced into the package. Making the build error disappear alone is not treated as sufficient.

Tests use PGlite with synthetic accounts and real migration SQL, actual PDF/DOCX/EML parsing, the parser subprocess and actual PDF rendering. The HTTP journey tests use an injected actor and scanner pass/fail stub; they do **not** prove production NextAuth, ClamAV, PostgreSQL concurrency, browser UX or deployment isolation. No live scanner was available during local testing. Build uses a dummy database URL; no live database is contacted by these fixture checks. Independent TypeScript validation is mandatory because the existing Next configuration skips build-time types.

Before enabling on Abacus: confirm the exact application and rollback route; rehearse both migrations on a disposable database; confirm generated Prisma client and traced parser/transitive packages in the deployed Node environment; test scanner availability/signatures, scanner rejection and resource exhaustion; check two real test accounts, uploads, refresh, review, download, revocation and mobile/desktop UI in the deployed browser; approve database/key custody, telemetry suppression, retention and recovery. Do not set `PRIVATE_EVIDENCE_RUNTIME_APPROVED=true` just to dismiss a disabled-state message.

Not included: OCR, Outlook MSG/PST archives, mailbox connectors, live URL ingestion, semantic/vector retrieval, entity linking across cases, redaction, maps/satellite comparison, grant eligibility calculations, CBAM calculations or identifiable child submissions. Templates guide the question; they do not claim specialist calculations or legal compliance.

Repaired build issue vs. remaining confidential-use requirements

The production-build failure has been repaired and validated. It is a separate concern from the confidential-use release blockers, which remain open. Each item below carries an owner and the evidence required to close it.

Item	Type	Owner	Evidence required / recorded
Parser worker launch compatible with the platform production build	Repaired build issue	This repair	RECORDED: <code>lib/workspaces/parser.ts</code> launches the worker via a runtime-assembled path; the platform's exact standalone production build compiles with zero worker-resolution errors; the same build with a static literal path reproduces the original errors; packaged <code>parser-process.mjs</code> exercised from <code>.build/standalone/app</code> parses synthetic PDF/DOCX/EML/TXT/CSV (all <code>status=PARSED</code>); private suite 28/28, evidence regression 25/25, <code>tsc --noEmit clean</code> , <code>prisma validate</code> valid
Persist parser dependency-tracing config (<code>serverExternalPackages / outputFileTracingIncludes</code>) in the deployed package	Deployment/config (platform-managed)	Platform / deployment owner	Confirm the deployed standalone package contains <code>parser-process.mjs</code> , <code>parse-file.mjs</code> and the <code>pdfjs-dist / mammoth / mailparser</code> closure, given <code>next.config.js</code> is platform-managed and reset on checkpoint; verified locally via faithful packaging reproduction but not yet persistable from source
			Approved org IdP with enforced MFA

Item	Type	Owner	Evidence required / recorded
MFA / trusted identity provider	Confidential-use blocker	Security / identity owner	(prefer passkeys), tested recovery and offboarding; identity tenant + application registration provisioned in the deployment environment
Host protection	Confidential-use blocker	Host / platform operations	clamscan installed with maintained signatures; externally enforced constraints on the parser child's native memory, filesystem and network; global request quotas; malicious compressed-input testing
Persistence & recovery	Confidential-use blocker	Data / platform operations	Both migrations rehearsed on a disposable hosted database; generated client + traced parser packages confirmed in the deployed Node environment; backup/restore verified; retention/deletion approved (only in-memory PGlite tested so far)
Database encryption at rest	Confidential-use blocker	Data / security owner	Extracted passages, metadata, review history and manifest columns protected at rest (file/PDF bytes already AES-256-GCM); 32-byte key held in the secret manager with tested recovery

Item	Type	Owner	Evidence required / recorded
Named-adult user acceptance	Confidential-use blocker	Product / pilot owner	A named adult tester assembles a representative case unaided using synthetic/de-identified material and checks every exported quote and date; time and corrections recorded, no invented success rate
Deploy / rollback route	Confidential-use blocker	Deployment owner	Exact Abacus application, preview route, deployment method and rollback confirmed and rehearsed

All private-workspace flags remain disabled and no production database has been migrated; the items above are prerequisites to enabling confidential use, not part of this build repair.

Adult pilot acceptance and ownership

The first target is an adult professional assembling a case file. Audio/video and school access are outside this release. No real children's essays, voices or identifiable material should enter this environment. A future school pilot needs educator-only accounts, a separate permissions model, reviewed de-identified submissions, sponsor access only to approved aggregate outputs, and the school's safeguarding/data-protection review.

Gate	Acceptance	Current state
File-to-case workflow	PDF, DOCX, EML with attachment, TXT and CSV produce locatable drafts; accepted entries export with sources	Automated fixture checks pass
Isolation	Account B cannot read/search/export account A's cases, including after revocation	Service/HTTP fixture checks pass; hosted two-account test pending
Authentication	MFA enforced by trusted identity provider; recovery and offboarding tested	Blocked on chosen organisation tenant and application registration
Host protection	Scanner with maintained signatures, constrained parser runtime, global quotas and no private telemetry	Host verification pending
Persistence	Migrations rehearsed, keys backed up, restoration verified, retention/deletion approved	Disposable PGLite migrations tested; hosted PostgreSQL/recovery pending
User acceptance	Named adult tester assembles a representative case without help and checks every exported quote/date	Pending hosted acceptance session; no speed saving claimed yet
Release	Exact Abacus app, preview route, deployment method and rollback confirmed	Not supplied; no production release

For the acceptance session, use synthetic or explicitly de-identified material first. Record the user's current time spent assembling one representative case, then repeat the same task with BioVeracity. Record time, corrections, omitted evidence and unusable steps; do not invent a success percentage. A successful build alone does not satisfy these gates.